

CAT.6 綜合資安風險報告

Combined CAT.6 Cyber Risk Report

Organization 組織

CAT.6 示範組織 (Demo Org)

Report 報告

Combined CAT.6 Cyber Risk Report · CAT.6 綜合資安風險報告

Assessor 評估者

CAT.6 Demo

Data Source 資料來源

CAT6_DEFAULT

Assessment 評估

CAT.6 綜合示範評估

Assessment Date 評估日期

2026-09-26

Generated 產生時間

2026-09-27 05:54

⚠ This analysis contains CAT.6 default / assumed values. 標示 CAT6_DEFAULT 的數值為示範 / 假設值，不代表組織實際狀況。

Contents 目錄

- | | |
|-----------------------------------|-----------------|
| 1. Executive Summary 執行摘要 | 含 DATA REQUIRED |
| 2. Assessment Scope 評估範圍 | 含 DATA REQUIRED |
| 3. Methodology 方法論 | |
| 4. Data Sources 資料來源 | |
| 5. Assumptions 假設 | |
| 6. Data Provenance 資料來源標示 | |
| 7. Risk Overview 風險概況 | |
| 8. Risk Matrix 風險矩陣 | |
| 9. Risk Register 風險登錄表 | 含 DATA REQUIRED |
| 10. Framework Analysis 框架分析 | 含 DATA REQUIRED |
| 11. FAIR Results 量化結果 | |
| 12. Risk Treatment 風險處理 | 含 DATA REQUIRED |
| 13. Residual Risk 殘餘風險 | 含 DATA REQUIRED |
| 14. ISO/IEC 27001 Readiness 驗證準備度 | |
| 15. Recommendations 建議 | |
| 16. References 參考文獻 | |
| 17. Disclaimer 免責聲明 | |

1 Executive Summary 執行摘要

本報告涵蓋 9 個風險情境：Critical 1、High 5、Medium 1、Low 2。風險等級依 CAT.6 5×5 平台準則判定（非 ISO 官方公式）。
風險處理：進行中 3、逾期 1、已完成 1。仍有 High / Critical 風險尚無處理計畫。
FAIR 量化（RS-B，100,000 次模擬，seed 20260926）：年化預期損失 Mean NT\$10,871,862，P90 NT\$16,818,436。
CAT.6 Readiness Indicator：57%（依 9 / 9 個有資料的領域等權平均；非 ISO 官方評分，不預測驗證結果）。
前五大風險（依分數）

Risk ID	Scenario	Score	Level	Treatment	Owner	Provenance 來源
RS-B	資料外洩：外部攻擊者利用 Firewall 重啟空窗	20	Critical	Accept	資訊部主管	USER_INPUT
RS-XL1	XLSX 匯入	16	High	—	—	FILE_IMPORT
RS-D1	勒索軟體加密營運系統（示範）	15	High	Mitigate	系統管理組	CAT6_DEFAULT
RS-D2	電力 / UPS 中斷導致服務停擺（示範）	12	High	Mitigate	總務部	CAT6_DEFAULT
RS-D3	釣魚郵件竊取帳號憑證（示範）	12	High	Mitigate	資訊部主管	CAT6_DEFAULT

⚠ This analysis contains CAT.6 default / assumed values.

2 Assessment Scope 評估範圍

Scope 範圍 示範範圍：總部資訊機房、ERP 營運系統、雲端檔案儲存與員工端點（僅供示範）	Assessment Type 類型 COMBINED
Frameworks 框架 ISO/IEC 27001、NIST CSF 2.0、NIST SP 800-30 Rev.1、CIS RAM v2.2、CIS Controls v8.1、FAIR	CIS Target IG IG1
CIS RAM Risk Acceptance Threshold Risk ≤ 9 → Accept (CAT6_DEFAULT)	CSF Implementation Tier 未填（選填）
Currency 幣別 TWD	
ISMS Scope Statement 示範：總部資訊機房與 ERP 營運服務	Boundaries 邊界 示範：總部實體場域與雲端檔案儲存
Interfaces 介面 DATA_REQUIRED	Exclusions 排除 —

3 Methodology 方法論

CAT.6 5×5 半定量矩陣：Risk Score = Likelihood (1-5) × Impact (1-5)。此 5×5 半定量方法為 CAT.6 平台自定義之 Risk Criteria（依 NIST 風險評估概念建立），分數區間與 L × I 計算並非 ISO/IEC 27001 或 NIST 官方公式 / 分數。

Risk Score → Risk Level 與建議處理原則

Risk Score	Risk Level	NIST 用語	中文	建議處理原則	處理方式
1-4	Low	Low	低風險	可接受或持續監控	Accept
5-9	Moderate	Moderate	中風險	評估並規劃適當控制措施	Accept / Monitor
10-16	High	High	高風險	優先制定風險處置與控制措施	Treatment Required
17-25	Critical	Very High	極高風險	優先處理並由管理階層關注	Immediate Treatment

Likelihood (L) 與 Impact (I) 五級文字描述

等級	Likelihood	Impact
1	L1 Rare 極低：在正常情況下幾乎不會發生；僅在特殊或極端條件下才可能發生，過去幾乎沒有相關事件紀錄。	I1 Insignificant 極低：對營運、資訊資產或服務幾乎沒有影響；資料與系統可立即恢復，不涉及重大財務、法律或聲譽損失。
2	L2 Unlikely 低：發生可能性偏低，但在特定條件或控制措施失效時仍可能發生；過去很少出現類似事件。	I2 Minor 低：造成局部或短暫影響；少量使用者、系統或資料受到影響，可透過一般作業程序快速處理。
3	L3 Possible 中：具有合理的發生可能性；相關威脅與弱點確實存在，且過去曾出現類似事件。	I3 Moderate 中：對重要系統或業務造成明顯影響；可能出現服務中斷、資料損失、額外處理成本或客戶影響，需要正式事件處理。
4	L4 Likely 高：很可能發生；威脅來源活躍、弱點明顯，或現有控制措施不足，類似事件已有多次發生紀錄。	I4 Major 高：對核心系統、重要資料或主要業務造成重大影響；可能涉及敏感資料外洩、長時間服務中斷、重大財務損失、法規或聲譽問題。
5	L5 Almost Certain 極高：預期很可能或反覆發生；威脅持續存在且弱點容易被利用，如果沒有額外控制措施，事件發生幾乎難以避免。	I5 Severe / Catastrophic 極高：對企業造成災難性影響；可能造成核心業務長時間或全面停止、大規模敏感資料外洩、重大法律與財務責任，甚至威脅企業持續營運。

NIST SP 800-30 Rev.1：Likelihood of Initiation (G-2 對抗性 / G-3 非對抗性) 與 Likelihood of Adverse Impact (G-4) 以 Table G-5 查表取得 Overall Likelihood (不相乘)；風險判定將 Overall Likelihood 與 Impact 依 VL→1 ... VH→5 換算，以 CAT.6 5×5 矩陣計分：Low 1-4、Moderate 5-9、High 10-16、Very High 17-25 (平台自訂，非 NIST 官方分數；Table I-2 僅列為參考)。

CIS RAM：以 CAT.6 5×5 準則記錄處理前 (Inherent) 與處理後 (Residual) 風險；Risk Acceptance Threshold = 9：Residual ≤ 門檻 → Accept (符合接受準則)，高於門檻 → Treatment Required。CAT.6 不代替 CIS RAM 官方計分公式。

CIS Controls v8.1：於控制層級依 IG1 / IG2 / IG3 記錄實施狀態；Coverage = 已實施 ÷ 已評估 (不含未評估與不適用)。Safeguard 層級資料需匯入 CAT6_CIS_Safeguards_Template。

NIST CSF 2.0：22 個 Category 以 CSF 2.0 Readiness Index 評分 (0 Not / 1 Partially / 2 Largely / 3 Fully Implemented)；Readiness % = $\sum \text{Current} \div (3 \times \text{已評分 Categories})$ ，對應 Initial 0-20、Developing 21-40、Defined 41-60、Managed 61-80、Optimized 81-100 (平台自訂 Index，非 NIST 官方分數)。Gap = $\max(0, \text{Target} - \text{Current})$ ，Target 未輸入時以 3 計。Implementation Tier 1-4 僅作治理描述。

FAIR：TEF = CF × PoA；LEF = TEF × Susceptibility；LM = Primary + Secondary Loss；Annual Risk = LEF × LM。各輸入以三角分布 Triangular(min, mode, max) 進行蒙地卡羅模擬 (可重現 seed)。

ISO/IEC 27001：條款 4-10 差異狀態與 Annex A (93 項) 適用性聲明。CAT.6 Readiness Indicator 為平台自定義之完成比例 (等權平均)，非 ISO/IEC 27001 官方評分，亦不預測驗證結果。

4 Data Sources 資料來源

評估設定之資料來源：CAT6_DEFAULT。資料在 本機瀏覽器 (LOCAL 模式) 保存。

最近的匯入紀錄

Time	Dataset	File	Rows	Errors
2026-09-27 05:54	risks	risks.xlsx	1	0
2026-09-27 05:54	risks	risks.csv	2	2

5 Assumptions 假設

- This analysis contains CAT.6 default / assumed values. 預設值版本 2026.09.27：未提供組織資料時的示範值；不是組織實際狀況、不是框架官方數值、不是稽核證據或驗證結果。
- 資料優先順序：組織輸入 (USER_INPUT) 與檔案匯入 (FILE_IMPORT) 優先；未輸入時以下表 CAT.6 預設值計算並標示 CAT6_DEFAULT。
- FAIR CF (CAT6_DEFAULT)：個案未提供實際資料；筆記註明應以 UPS、Firewall、SIEM 與電力事件紀錄校正。
- FAIR PoA (CAT6_DEFAULT)：外部攻擊者已持續觀察目標，行動機率假設高於隨機掃描。
- FAIR Susceptibility (CAT6_DEFAULT)：Threat Capability 高 (可捕捉 Firewall 重啟空窗)；Resistance Strength 弱。
- FAIR PrimaryLoss (CAT6_DEFAULT)：採筆記 Python 引擎值。筆記 Step 3 文字寫 1,125,000，與程式不一致，詳見 docs/METHODOLOGY-NOTES.md。

- FAIR SecondaryLoss (CAT6_DEFAULT)：以台灣法規與實際個資外洩案件為錨點（筆記 Step 2）。

預設值與採用依據

項目	本報告採用值	來源	採用依據	依據文件
5×5 風險計分與等級	Score = L × I ; 1-4 Low · 5-9 Moderate · 10-16 High · 17-25 Critical / Very High	◇ CAT6_DEFAULT	Risk_Criteria.pdf 與「NIST SP 800-30 的風險判定」：平台依 NIST 風險評估概念建立之 5×5 半定量矩陣；分數區間為平台自訂，非 ISO / NIST 官方分數。	Risk_Criteria.pdf；確認_NIST_Table_I-2_與_H-3.pdf
Likelihood / Impact 五級文字描述	L1 Rare ... L5 Almost Certain ; I1 Insignificant ... I5 Severe / Catastrophic	◇ CAT6_DEFAULT	專案提供之 5×5 L / I 文字描述，作為評分者一致判斷的依據。	5_5_各等級_L_I_的文字描述.pdf
NIST SP 800-30 風險判定	G-5 查表取得 Overall Likelihood ; VL..VH → 1..5 後以 5×5 計分	◇ CAT6_DEFAULT	G-2 / G-3 / G-4 / G-5 依 Risk_Criteria.pdf (NIST SP 800-30 Rev.1 Appendix G)；風險判定依專案提供之平台 5×5 方法。Table I-2 僅列為參考。	Risk_Criteria.pdf；確認_NIST_Table_I-2_與_H-3.pdf
CIS RAM Risk Acceptance Threshold	9 5×5 分數	◇ CAT6_DEFAULT	專案提供之 CIS RAM 可接受準則：Risk ≤ 9 → Accept (符合接受準則)；Risk ≥ 10 → Treatment Required。9 為 Moderate 區間上限，High 以上一律需處理。組織可於 Setup 改為自己的門檻。	CIS_RAM_可接受風險門檻.pdf
CIS Controls 目標 Implementation Group	IG1	◇ CAT6_DEFAULT	CIS Controls v8.1 將 IG1 定義為「基本資安衛生 (essential cyber hygiene)」，是所有企業都應達到的最低基準；組織規模或資料敏感度較高時應自行提高為 IG2 / IG3。	CIS Critical Security Controls v8.1
CSF 2.0 Readiness Index	0 Not · 1 Partially · 2 Largely · 3 Fully Implemented ; Readiness % → Initial / Developing / Defined / Managed / Optimized	◇ CAT6_DEFAULT	專案提供之 CSF 2.0 Readiness Index (平台自訂 Index，非 NIST 官方公式)；Tier 1-4 僅作治理成熟度描述，不作為分數。	正式的_Readiness_評分方法.pdf
CSF Target Profile (未輸入時)	3 0-3	◇ CAT6_DEFAULT	Readiness Index 的完整實施點 (3 = Fully Implemented)；未設定 Target 的 Category 以 3 計算差距，使差距代表「距離完整實施」。組織設定 Target 後即以組織值為準。	正式的_Readiness_評分方法.pdf
ISO/IEC 27001 Readiness Indicator	九個領域完成比例之等權平均 (無資料之領域不計入)	◇ CAT6_DEFAULT	專案未提供 ISO 27001 專用之正式評分方法 (提供之 Readiness 文件為 CSF 2.0 Index)，因此採最透明的等權完成比例；非 ISO 官方評分、不預測驗證結果。	CAT.6 平台方法
FAIR 三點估計 (CF、PoA、Susceptibility、PL、SL)	Scenario B 資料外洩	◇ CAT6_DEFAULT	FAIR筆記-20260926-Iris.md 之 Scenario B 與其 Python 程式設定 (不一致處見 METHODOLOGY-NOTES)。	FAIR筆記-20260926-Iris.md
FAIR 模擬次數 / Seed	1,000,000 次 · seed 20260926	◇ CAT6_DEFAULT	FAIR 筆記之蒙地卡羅設定；相同 seed 可重現。	FAIR筆記-20260926-Iris.md
幣別	TWD	◇ CAT6_DEFAULT	FAIR 筆記所有金額以新台幣 (NT\$) 表示。	FAIR筆記-20260926-Iris.md
示範資料集 (風險、處理、ISO、證據等)	CAT.6 示範組織	◇ CAT6_DEFAULT	未匯入組織資料時，用於展示完整流程的示範情境 (以 FAIR 筆記 Scenario B 為核心)；每筆標示 CAT6_DEFAULT，不代表任何組織實際狀況。	CAT.6 示範資料

6 Data Provenance 資料來源標示

四種來源：USER_INPUT (組織輸入)、FILE_IMPORT (檔案匯入)、CAT6_DEFAULT (CAT.6 DEFAULT / ASSUMED VALUE)、CALCULATED (系統計算)。所有計算結果 (分數、等級、覆蓋率、差距、模擬結果) 皆為 CALCULATED。

各資料集的來源統計

Dataset	USER_INPUT	FILE_IMPORT	CAT6_DEFAULT	CALCULATED	Total
risks	1	3	5	0	9
treatments	1	0	4	0	5
nist	1	0	3	0	4
cisram	1	0	3	0	4
cisControls	0	0	18	0	18

Dataset	USER_INPUT	FILE_IMPORT	CAT6_DEFAULT	CALCULATED	Total
csf	0	0	22	0	22
isoContext	0	0	1	0	1
isoClauses	0	0	25	0	25
isoSoa	0	0	21	0	21
audits	1	0	2	0	3
findings	0	0	3	0	3
capas	0	0	2	0	2
reviews	0	0	1	0	1
evidence	1	0	6	0	7
fairInputs	0	0	1	0	1
fairRuns	0	0	0	1	1

7 Risk Overview 風險概況

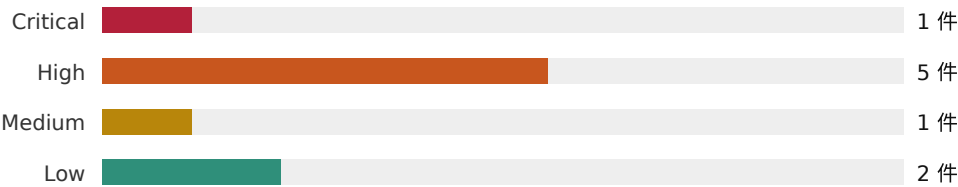


Figure · 風險等級分布 (CAT.6 5×5)
共 9 個情境：Critical 1、High 5、Medium 1、Low 2。

8 Risk Matrix 風險矩陣

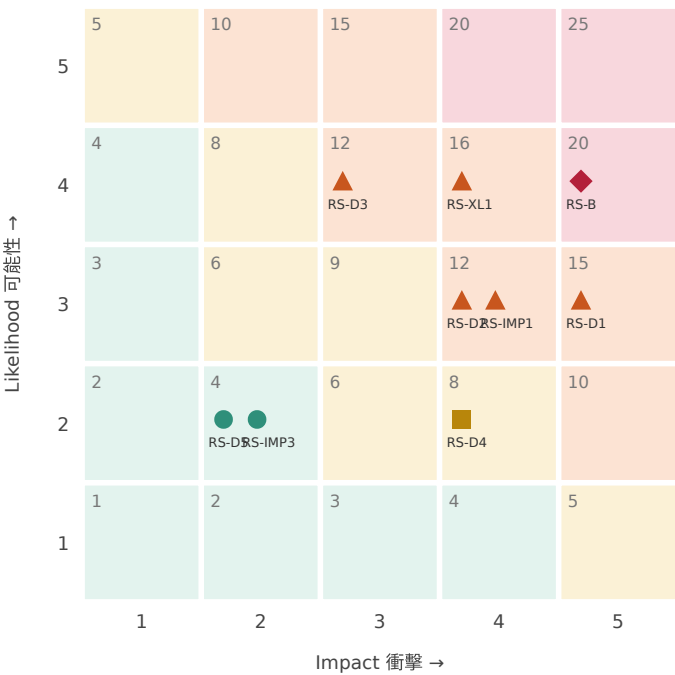


Figure · CAT.6 5×5 Risk Matrix (形狀 + 文字標示等級，不只依賴顏色)
矩陣標示 9 個已評估情境；所有情境皆已標示。

9 Risk Register 風險登錄表

Risk Register (9 筆，依分數排序)

Risk ID	Scenario	Asset	Threat Source	Threat Event	Vulnerability	Existing Controls	L	I	Score	Level	Treatment	Owner	Due	Status	Residual	Provenance 來源
RS-B	資料外洩：外部攻擊者利用 Firewall 重啟空窗	客戶個資資料庫	外部攻擊者	於 Firewall 重啟期間滲透並外洩資料	Firewall 重啟期間無替代過濾	SIEM 告警（部分覆蓋）	4	5	20	Critical	Accept	資訊部主管	2026-12-31	In review	DATA REQUIRED	USER_INPUT
RS-XL1	XLSX 匯入	資料庫	—	—	—	—	4	4	16	High	—	—	—	Draft	DATA REQUIRED	FILE_IMPORT
RS-D1	勒索軟體加密營運系統（示範）	ERP 營運伺服器	勒索軟體集團	加密營運資料並勒索	遠端存取服務未即時修補	端點防毒、每週備份	3	5	15	High	Mitigate	系統管理組	2026-09-15	Treatment planned	8 · Moderate	CAT6_DEFAULT
RS-D2	電力 / UPS 中斷導致服務停擺（示範）	資訊機房	電力供應異常	UPS 失效造成主機斷電	UPS 電池老化	UPS 年度檢查	3	4	12	High	Mitigate	總務部	2026-11-30	Assessed	6 · Moderate	CAT6_DEFAULT
RS-D3	釣魚郵件竊取帳號憑證（示範）	員工郵件帳號	外部攻擊者	釣魚郵件誘導輸入密碼	未全面啟用多因子驗證	郵件過濾	4	3	12	High	Mitigate	資訊部主管	2026-10-31	Assessed	6 · Moderate	CAT6_DEFAULT
RS-IMP1	匯入測試一	伺服器	—	—	—	—	3	4	12	High	—	—	—	Draft	DATA REQUIRED	FILE_IMPORT
RS-D4	雲端儲存權限設定錯誤（示範）	雲端檔案儲存	內部人員（非蓄意）	共享連結公開導致資料外洩	缺乏共享權限定期檢視	無	2	4	8	Moderate	Mitigate	資訊部主管	2027-01-31	Draft	DATA REQUIRED	CAT6_DEFAULT
RS-D5	內部人員誤刪共用資料（示範）	檔案伺服器	內部人員（非蓄意）	誤刪共用資料夾	共用資料夾權限過寬	每日備份	2	2	4	Low	Accept	各部門主管	—	Assessed	4 · Low	CAT6_DEFAULT
RS-IMP3	匯入測試三	NAS	—	—	—	—	2	2	4	Low	—	—	—	Draft	DATA REQUIRED	FILE_IMPORT

10 Framework Analysis 框架分析

NIST SP 800-30 Rev.1

NIST SP 800-30 評鑑 (G-5 查表與 5×5 分數為 CALCULATED)

ID	Risk	Threat Event	Overall Likelihood	Impact	Risk (CAT.6 5×5)	Provenance 來源
NA-001	RS-B	利用 Firewall 重啟空窗滲透並外洩客戶資料	G-5 · High	High	4×4=16 · High	CAT6_DEFAULT
NA-002	RS-D2	UPS 失效造成主機斷電	G-5 · Moderate	Moderate	3×3=9 · Moderate	CAT6_DEFAULT
NA-003	RS-D5	誤刪共用資料夾	G-5 · Low	Low	2×2=4 · Low	CAT6_DEFAULT
NA-004	—	E2E 測試資料	G-5 · Very Low	Very Low	1×1=1 · Low	USER_INPUT

CIS RAM

Risk Acceptance Threshold : Residual ≤ 9 → Accept ; ≥ 10 → Treatment Required (CAT6_DEFAULT, 依據: CIS_RAM_可接受風險門檻.pdf)。

CIS RAM 工作表

ID	Scenario	Inherent	Residual	Acceptability	Provenance 來源
CR-001	勒索軟體加密營運系統	20 · Critical	8 · Moderate	Accept	CAT6_DEFAULT
CR-002	雲端儲存權限設定錯誤	12 · High	6 · Moderate	Accept	CAT6_DEFAULT
CR-003	資料外洩: Firewall 重啟空窗	20 · Critical	12 · High	Treatment Required	CAT6_DEFAULT
CR-004	E2E 測試資料	1 · Low	DATA_REQUIRED	DATA_REQUIRED (缺少處理後 Likelihood / Impact)	USER_INPUT

CIS Controls v8.1



Figure · CIS Controls 控制層級覆蓋率 (已實施 + 已評估)
IG1 22%、IG2 6%、IG3 0%。

Target IG1 缺口 (14 項控制)

Control	Title	Missing IG	Status
CIS-02	Inventory and Control of Software Assets (軟體資產盤點與控制)	IG1	IG1 PARTIAL
CIS-03	Data Protection (資料保護)	IG1	IG1 PARTIAL
CIS-04	Secure Configuration of Enterprise Assets and Software (安全組態)	IG1	IG1 PARTIAL
CIS-06	Access Control Management (存取控制)	IG1	IG1 PARTIAL
CIS-07	Continuous Vulnerability Management (持續弱點管理)	IG1	IG1 PARTIAL
CIS-08	Audit Log Management (稽核日誌管理)	IG1	IG1 PARTIAL
CIS-11	Data Recovery (資料復原)	IG1	IG1 PARTIAL
CIS-12	Network Infrastructure Management (網路基礎設施管理)	IG1	IG1 PARTIAL
CIS-13	Network Monitoring and Defense (網路監控與防禦)	IG1	IG1 NOT_IMPLEMENTED
CIS-14	Security Awareness and Skills Training (資安意識與技能訓練)	IG1	IG1 PARTIAL
CIS-15	Service Provider Management (服務供應商管理)	IG1	IG1 NOT_IMPLEMENTED
CIS-16	Application Software Security (應用程式安全)	IG1	IG1 NOT_IMPLEMENTED

Control	Title	Missing IG	Status
CIS-17	Incident Response Management (事件回應管理)	IG1	IG1 PARTIAL
CIS-18	Penetration Testing (滲透測試)	IG1	IG1 NOT_IMPLEMENTED

△ Safeguard 層級覆蓋率：DATA REQUIRED (需匯入 CIS Controls v8.1 Safeguard 清單 CAT6_CIS_Safeguards_Template)

NIST CSF 2.0

CSF 2.0 Readiness

41% · Defined (多項要求已建立，但仍有明顯 Gap)

Implementation Tier

未填 (選填，治理描述)

Based on

22 / 22 Categories

CSF 2.0 Readiness by Function

Function	Readiness	Level	Current → Target
GV GOVERN	44%	Defined	1.3 → 2.8
ID IDENTIFY	44%	Defined	1.3 → 2.7
PR PROTECT	53%	Defined	1.6 → 3.0
DE DETECT	33%	Developing	1.0 → 2.5
RS RESPOND	33%	Developing	1.0 → 2.3
RC RECOVER	17%	Initial	0.5 → 2.5

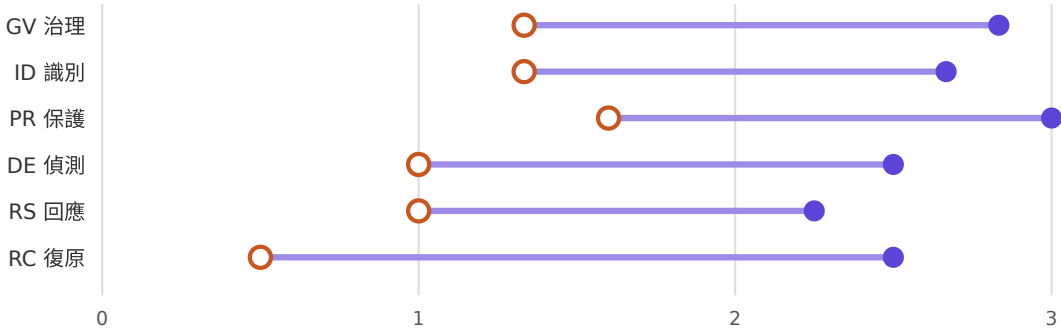


Figure · CSF Function Current (空心) → Target (實心) , Readiness Index 0-3
GV 1.3 → 2.8 ; ID 1.3 → 2.7 ; PR 1.6 → 3.0 ; DE 1.0 → 2.5 ; RS 1.0 → 2.3 ; RC 0.5 → 2.5 °

CSF 2.0 Category Profile

Category	Name	Current	Target	Gap	Improvement Action	Provenance 來源
GV.OC	Organizational Context	2	3	1	示範改善行動：提升至目標層級	CAT6_DEFAULT
GV.RM	Risk Management Strategy	1	3	2	示範改善行動：提升至目標層級	CAT6_DEFAULT
GV.RR	Roles, Responsibilities, and Authorities	2	3	1	示範改善行動：提升至目標層級	CAT6_DEFAULT
GV.PO	Policy	2	3	1	示範改善行動：提升至目標層級	CAT6_DEFAULT
GV.OV	Oversight	1	3	2	示範改善行動：提升至目標層級	CAT6_DEFAULT
GV.SC	Cybersecurity Supply Chain Risk Management	0	2	2	示範改善行動：提升至目標層級	CAT6_DEFAULT

Category	Name	Current	Target	Gap	Improvement Action	Provenance 來源
ID.AM	Asset Management	2	3	1	示範改善行動：提升至目標層級	CAT6_DEFAULT
ID.RA	Risk Assessment	1	3	2	示範改善行動：提升至目標層級	CAT6_DEFAULT
ID.IM	Improvement	1	2	1	示範改善行動：提升至目標層級	CAT6_DEFAULT
PR.AA	Identity Management, Authentication, and Access Control	2	3	1	示範改善行動：提升至目標層級	CAT6_DEFAULT
PR.AT	Awareness and Training	1	3	2	示範改善行動：提升至目標層級	CAT6_DEFAULT
PR.DS	Data Security	2	3	1	示範改善行動：提升至目標層級	CAT6_DEFAULT
PR.PS	Platform Security	2	3	1	示範改善行動：提升至目標層級	CAT6_DEFAULT
PR.IR	Technology Infrastructure Resilience	1	3	2	示範改善行動：提升至目標層級	CAT6_DEFAULT
DE.CM	Continuous Monitoring	1	3	2	示範改善行動：提升至目標層級	CAT6_DEFAULT
DE.AE	Adverse Event Analysis	1	2	1	示範改善行動：提升至目標層級	CAT6_DEFAULT
RS.MA	Incident Management	1	3	2	示範改善行動：提升至目標層級	CAT6_DEFAULT
RS.AN	Incident Analysis	1	2	1	示範改善行動：提升至目標層級	CAT6_DEFAULT
RS.CO	Incident Response Reporting and Communication	1	2	1	示範改善行動：提升至目標層級	CAT6_DEFAULT
RS.MI	Incident Mitigation	1	2	1	示範改善行動：提升至目標層級	CAT6_DEFAULT
RC.RP	Incident Recovery Plan Execution	1	3	2	示範改善行動：提升至目標層級	CAT6_DEFAULT
RC.CO	Incident Recovery Communication	0	2	2	示範改善行動：提升至目標層級	CAT6_DEFAULT

Framework Mapping

CAT.6 整合框架模型（領域 → 框架）

Domain	中文	Frameworks
Governance	治理	ISO/IEC 27001、NIST CSF 2.0
Cybersecurity Posture	資安態勢	NIST CSF 2.0
Risk Assessment	風險評鑑	NIST SP 800-30 Rev.1、CIS RAM v2.2
Quantification	量化	FAIR
Security Controls	安全控制	CIS Controls v8.1
Risk Treatment	風險處理	ISO/IEC 27001、CIS RAM v2.2、CIS Controls v8.1
Continual Improvement	持續改善	ISO/IEC 27001、NIST CSF 2.0

風險情境對應（框架 / 控制 / 處理對應）

Risk	Scenario	Frameworks	CIS Controls	ISO Annex A	CSF	SP 800-30	FAIR	Provenance 來源
RS-B	資料外洩：外部攻擊者利用 Firewall 重啟空窗	NIST SP 800-30 Rev.1, FAIR, CIS Controls v8.1, ISO/IEC 27001	CIS-12, CIS-13	A.8.20, A.8.14	PR.IR	NA-001	已量化	USER_INPUT
RS-D1	勒索軟體加密營運系統（示範）	CIS RAM v2.2, CIS Controls v8.1	CIS-07, CIS-10, CIS-11	A.8.13	PR.DS, RC.RP	—	—	CAT6_DEFAULT
RS-D2	電力 / UPS 中斷導致服務停擺（示範）	NIST SP 800-30 Rev.1, NIST CSF 2.0	—	A.7.11	PR.IR	NA-002	—	CAT6_DEFAULT
RS-D3	釣魚郵件竊取帳號憑證（示範）	NIST CSF 2.0, CIS Controls v8.1	CIS-06, CIS-09, CIS-14	A.5.17, A.8.5	PR.AA	—	—	CAT6_DEFAULT
RS-D4	雲端儲存權限設定錯誤（示範）	CIS RAM v2.2, ISO/IEC 27001	CIS-03	—	—	—	—	CAT6_DEFAULT
RS-D5	內部人員誤刪共用資料（示範）	NIST SP 800-30 Rev.1	—	—	—	NA-003	—	CAT6_DEFAULT
RS-IMP1	匯入測試一	—	—	—	—	—	—	FILE_IMPORT
RS-IMP3	匯入測試三	—	—	—	—	—	—	FILE_IMPORT
RS-XL1	XLSX 匯入	—	—	—	—	—	—	FILE_IMPORT

ISO/IEC 27001 Gap Assessment

條款 4-10 共 25 項：已實施 3、部分實施 11、未實施 8、未評估 3。

Clause Gap Assessment

Clause	Title	Status	Gap Note	Owner	Due	Provenance 來源
4.1	Understanding the organization and its context · 了解組織及其全景	IMPLEMENTED	—	—	—	CAT6_DEFAULT
4.2	Understanding the needs and expectations of interested parties · 了解利害關係者之需要與期望	IMPLEMENTED	—	—	—	CAT6_DEFAULT
4.3	Determining the scope of the ISMS · 決定 ISMS 範圍	PARTIAL	—	—	—	CAT6_DEFAULT
4.4	Information security management system · 資訊安全管理系統	PARTIAL	—	—	—	CAT6_DEFAULT
5.1	Leadership and commitment · 領導與承諾	PARTIAL	—	—	—	CAT6_DEFAULT
5.2	Policy · 政策	IMPLEMENTED	—	—	—	CAT6_DEFAULT
5.3	Organizational roles, responsibilities and authorities · 組織角色、責任與權限	PARTIAL	—	—	—	CAT6_DEFAULT
6.1.1	Actions to address risks and opportunities — General · 因應風險與機會之行動—一般要求	PARTIAL	—	—	—	CAT6_DEFAULT
6.1.2	Information security risk assessment · 資訊安全風險評鑑	PARTIAL	—	—	—	CAT6_DEFAULT
6.1.3	Information security risk treatment · 資訊安全風險處理	NOT_IMPLEMENTED	—	—	—	CAT6_DEFAULT
6.2	Information security objectives and planning to achieve them · 資訊安全目標及其達成規劃	NOT_IMPLEMENTED	—	—	—	CAT6_DEFAULT
6.3	Planning of changes · 變更之規劃	NOT_ASSESSED	—	—	—	CAT6_DEFAULT
7.1	Resources · 資源	PARTIAL	—	—	—	CAT6_DEFAULT
7.2	Competence · 適任性	PARTIAL	—	—	—	CAT6_DEFAULT
7.3	Awareness · 認知	NOT_IMPLEMENTED	—	—	—	CAT6_DEFAULT
7.4	Communication · 溝通	PARTIAL	—	—	—	CAT6_DEFAULT
7.5	Documented information · 文件化資訊	PARTIAL	—	—	—	CAT6_DEFAULT

Clause	Title	Status	Gap Note	Owner	Due	Provenance 來源
8.1	Operational planning and control · 運作之規劃及控制	NOT_ASSESSED	—	—	—	◇ CAT6_DEFAULT
8.2	Information security risk assessment · 資訊安全風險評鑑 (執行)	PARTIAL	—	—	—	◇ CAT6_DEFAULT
8.3	Information security risk treatment · 資訊安全風險處理 (執行)	NOT_IMPLEMENTED	—	—	—	◇ CAT6_DEFAULT
9.1	Monitoring, measurement, analysis and evaluation · 監督、量測、分析及評估	NOT_IMPLEMENTED	—	—	—	◇ CAT6_DEFAULT
9.2	Internal audit · 內部稽核	NOT_IMPLEMENTED	—	—	—	◇ CAT6_DEFAULT
9.3	Management review · 管理審查	NOT_IMPLEMENTED	—	—	—	◇ CAT6_DEFAULT
10.1	Continual improvement · 持續改善	NOT_ASSESSED	—	—	—	◇ CAT6_DEFAULT
10.2	Nonconformity and corrective action · 不符合事項及矯正措施	NOT_IMPLEMENTED	—	—	—	◇ CAT6_DEFAULT

Statement of Applicability : Annex A 93 項中已決定適用性 21 項；未決定者列為「未決定」。排除之控制必須提供理由。

Statement of Applicability (已決定項目)

Control	Theme	Title	Applicable	Status	Justification	Provenance 來源
A.5.1	Organization 組織	Policies for information security	Yes	IMPLEMENTED	示範：對應已識別風險	◇ CAT6_DEFAULT
A.5.2	Organization 組織	Information security roles and responsibilities	Yes	PARTIAL	示範：對應已識別風險	◇ CAT6_DEFAULT
A.5.9	Organization 組織	Inventory of information and other associated assets	Yes	PARTIAL	示範：對應已識別風險	◇ CAT6_DEFAULT
A.5.15	Organization 組織	Access control	Yes	PARTIAL	示範：對應已識別風險	◇ CAT6_DEFAULT
A.5.17	Organization 組織	Authentication information	Yes	PARTIAL	示範：對應已識別風險	◇ CAT6_DEFAULT
A.5.23	Organization 組織	Information security for use of cloud services	Yes	NOT_IMPLEMENTED	示範：對應已識別風險	◇ CAT6_DEFAULT
A.5.24	Organization 組織	Information security incident management planning and preparation	Yes	NOT_IMPLEMENTED	示範：對應已識別風險	◇ CAT6_DEFAULT
A.5.30	Organization 組織	ICT readiness for business continuity	Yes	NOT_IMPLEMENTED	示範：對應已識別風險	◇ CAT6_DEFAULT
A.5.34	Organization 組織	Privacy and protection of PII	Yes	PARTIAL	示範：對應已識別風險	◇ CAT6_DEFAULT
A.6.3	People 人員	Information security awareness, education and training	Yes	NOT_IMPLEMENTED	示範：對應已識別風險	◇ CAT6_DEFAULT
A.7.11	Physical 實體	Supporting utilities	Yes	IMPLEMENTED	示範：對應已識別風險	◇ CAT6_DEFAULT
A.8.4	Technological 技術	Access to source code	No	—	示範：組織無自行開發之原始碼	◇ CAT6_DEFAULT
A.8.5	Technological 技術	Secure authentication	Yes	PARTIAL	示範：對應已識別風險	◇ CAT6_DEFAULT

Control	Theme	Title	Applicable	Status	Justification	Provenance 來源
A.8.7	Technological 技術	Protection against malware	Yes	IMPLEMENTED	示範：對應已識別風險	◇ CAT6_DEFAULT
A.8.8	Technological 技術	Management of technical vulnerabilities	Yes	PARTIAL	示範：對應已識別風險	◇ CAT6_DEFAULT
A.8.13	Technological 技術	Information backup	Yes	PARTIAL	示範：對應已識別風險	◇ CAT6_DEFAULT
A.8.14	Technological 技術	Redundancy of information processing facilities	Yes	NOT_IMPLEMENTED	示範：對應已識別風險	◇ CAT6_DEFAULT
A.8.15	Technological 技術	Logging	Yes	PARTIAL	示範：對應已識別風險	◇ CAT6_DEFAULT
A.8.16	Technological 技術	Monitoring activities	Yes	PARTIAL	示範：對應已識別風險	◇ CAT6_DEFAULT
A.8.20	Technological 技術	Networks security	Yes	PARTIAL	示範：對應已識別風險	◇ CAT6_DEFAULT
A.8.30	Technological 技術	Outsourced development	No	—	示範：無委外開發	◇ CAT6_DEFAULT

11 FAIR Results 量化結果

Risk Scenario	Run
RS-B	RUN-0001 · 2026-09-27 05:54
Iterations	Random Seed
100,000	20260926
Engine	Annual Risk Mean (ALE)
Web Worker	NT\$10,871,862
Annual Risk P90	Annual Risk P95
NT\$16,818,436	NT\$19,054,225

⚠ This analysis contains CAT.6 default / assumed values. (FAIR 輸入含 CAT6_DEFAULT)

FAIR 輸入 (三點估計)

Input	Min	Most Likely	Max	Unit	Provenance 來源
CF	2	4	6	events/year	CAT6_DEFAULT
PoA	0.5	0.6	0.8	probability	CAT6_DEFAULT
Susceptibility	0.6	0.75	0.8	probability	CAT6_DEFAULT
PrimaryLoss	1425000	1530000	2600000	TWD	CAT6_DEFAULT
SecondaryLoss	600000	2600000	9200000	TWD	CAT6_DEFAULT

模擬結果百分位 (CALCULATED)

Output	P10	P25	P50	Mean	P75	P90	P95
TEF	1.789	2.119	2.510	2.533	2.921	3.299	3.526
LEF	1.268	1.506	1.794	1.815	2.100	2.384	2.554
PrimaryLoss	NT\$1,536,207	NT\$1,629,465	NT\$1,808,165	NT\$1,852,417	NT\$2,040,401	NT\$2,246,485	NT\$2,349,200
SecondaryLoss	NT\$1,906,992	NT\$2,676,627	NT\$3,884,323	NT\$4,136,816	NT\$5,434,963	NT\$6,810,310	NT\$7,514,211
LM	NT\$3,733,216	NT\$4,523,124	NT\$5,742,303	NT\$5,989,232	NT\$7,300,519	NT\$8,672,353	NT\$9,388,809
AnnualRisk	NT\$5,941,680	NT\$7,653,341	NT\$10,167,493	NT\$10,871,862	NT\$13,394,630	NT\$16,818,436	NT\$19,054,225

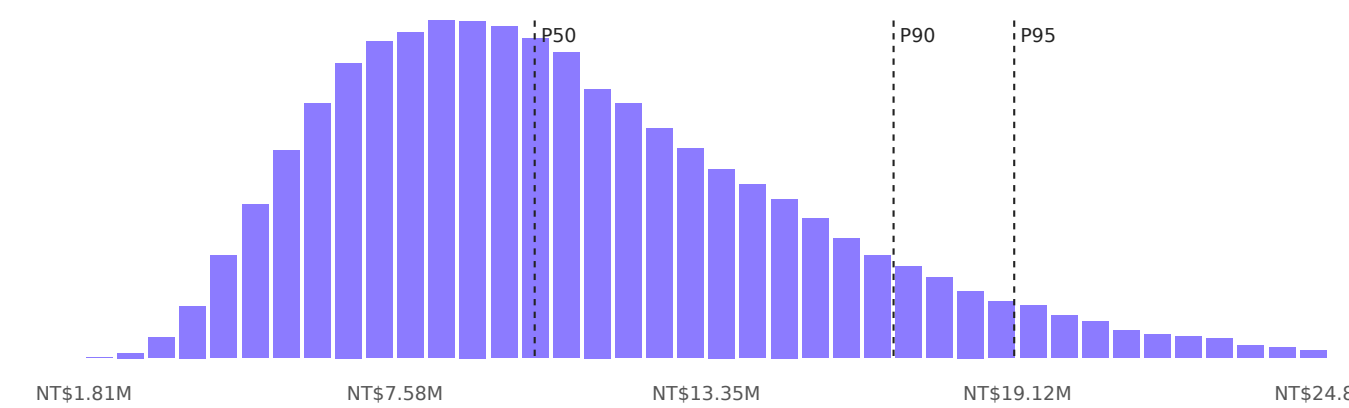


Figure · Annual Risk 分布 (顯示至 P99.5)
中位數 NT\$10,167,493，平均 NT\$10,871,862，P95 NT\$19,054,225。

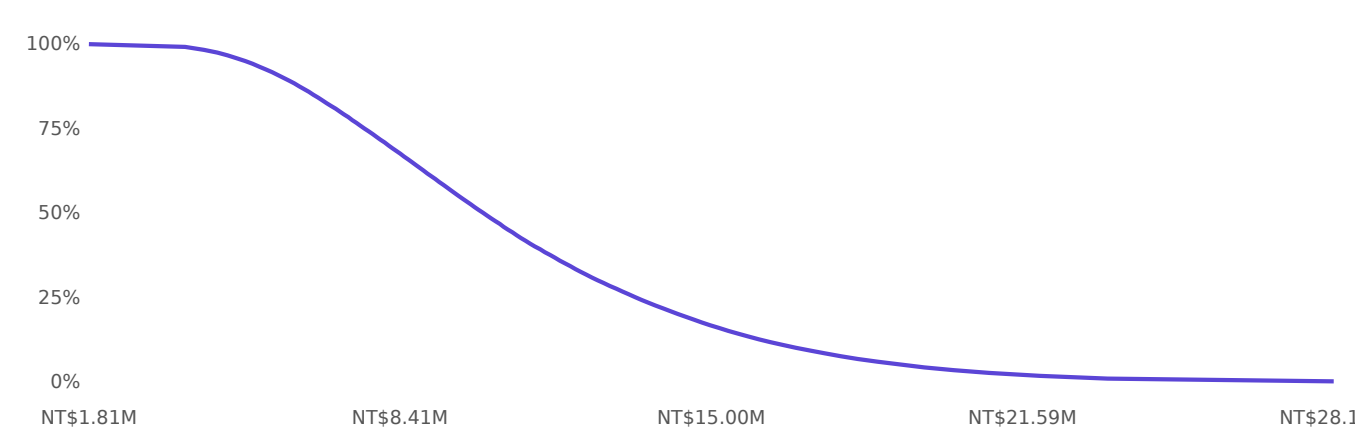


Figure · Loss Exceedance Curve
年度損失超過 NT\$16,818,436 的機率約 10%。

12 Risk Treatment 風險處理

處理計畫 5 項：進行中 3、逾期 1、已完成 1、取消 0。

Risk Treatment Plan

ID	Risk	Scenario	Current Risk	Strategy	Selected Control	Framework	Mapping	Owner	Priority	Due	Status	Residual	Provenance 來源
TR-001	RS-B	資料外洩：外部攻擊者利用 Firewall 重啟空窗	20 · Critical	Mitigate	建置 Firewall HA 並於重啟期間啟用備援過濾	CIS Controls v8.1	ISO: A.8.20, A.8.14 ; CSF: PR.IR ; CIS: CIS-12, CIS-13	資訊部主管	P1	2026-12-31	In progress	DATA REQUIRED	CAT6_DEFAULT
TR-002	RS-D1	勒索軟體加密營運系統 (示範)	15 · High	Mitigate	離線備份與季度還原演練	CIS Controls v8.1	ISO: A.8.13 ; CSF: PR.DS, RC.RP ; CIS: CIS-11	系統管理組	P1	2026-09-15	In progress (逾期)	8 · Moderate	CAT6_DEFAULT
TR-003	RS-D3	釣魚郵件竊取帳號憑證 (示範)	12 · High	Mitigate	全員啟用多因子驗證	ISO/IEC 27001	ISO: A.5.17, A.8.5 ; CSF: PR.AA ; CIS: CIS-06	資訊部主管	P2	2026-10-31	Planned	6 · Moderate	CAT6_DEFAULT
TR-004	RS-D2	電力 / UPS 中斷導致服務停擺 (示範)	12 · High	Mitigate	更換 UPS 電池並建立雙迴路供電	ISO/IEC 27001	ISO: A.7.11 ; CSF: PR.IR	總務部	P2	2026-08-31	Completed	6 · Moderate	CAT6_DEFAULT
TR-005	RS-B	資料外洩：外部攻擊者利用 Firewall 重啟空窗	20 · Critical	Accept	E2E 測試資料	ISO/IEC 27001	—	E2E 測試資料	P1	2026-12-31	Planned	DATA REQUIRED	USER_INPUT

尚無處理計畫的風險：RS-D4 (Moderate)、RS-IMP1 (High)、RS-IMP3 (Low)、RS-XL1 (High)。

13 Residual Risk 殘餘風險

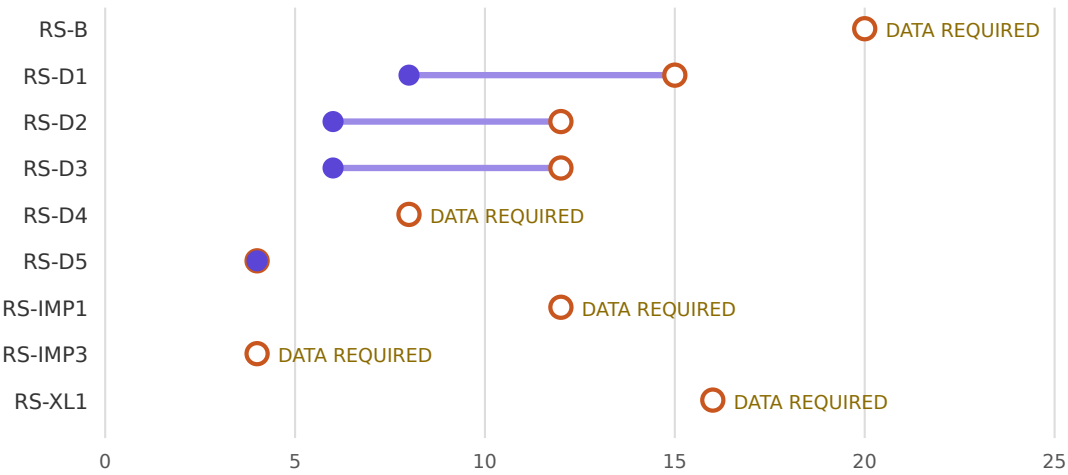


Figure · Current (空心) → Residual (實心) · CAT.6 5×5 分數
4 / 9 個情境已記錄殘餘風險；其餘標示 DATA REQUIRED。

Residual Risk

Risk	Scenario	Current	Residual	Reduction	Provenance 來源
RS-B	資料外洩：外部攻擊者利用 Firewall 重啟空窗	20 · Critical	DATA REQUIRED	DATA REQUIRED	USER INPUT
RS-D1	勒索軟體加密營運系統（示範）	15 · High	8 · Moderate	7	CAT6_DEFAULT
RS-D2	電力 / UPS 中斷導致服務停擺（示範）	12 · High	6 · Moderate	6	CAT6_DEFAULT
RS-D3	釣魚郵件竊取帳號憑證（示範）	12 · High	6 · Moderate	6	CAT6_DEFAULT
RS-D4	雲端儲存權限設定錯誤（示範）	8 · Moderate	DATA REQUIRED	DATA REQUIRED	CAT6_DEFAULT
RS-D5	內部人員誤刪共用資料（示範）	4 · Low	4 · Low	0	CAT6_DEFAULT
RS-IMP1	匯入測試一	12 · High	DATA REQUIRED	DATA REQUIRED	FILE_IMPORT
RS-IMP3	匯入測試三	4 · Low	DATA REQUIRED	DATA REQUIRED	FILE_IMPORT
RS-XL1	XLSX 匯入	16 · High	DATA REQUIRED	DATA REQUIRED	FILE_IMPORT

14 ISO/IEC 27001 Readiness 驗證準備度

① CAT.6 Readiness Indicator 為平台自定義之完成比例（等權平均），非 ISO/IEC 27001 官方評分，亦不預測驗證結果。CAT.6 不是驗證機構（Certification Body），不核發證書。

CAT.6 Readiness Indicator

57%

Based on

9 / 9 areas with data

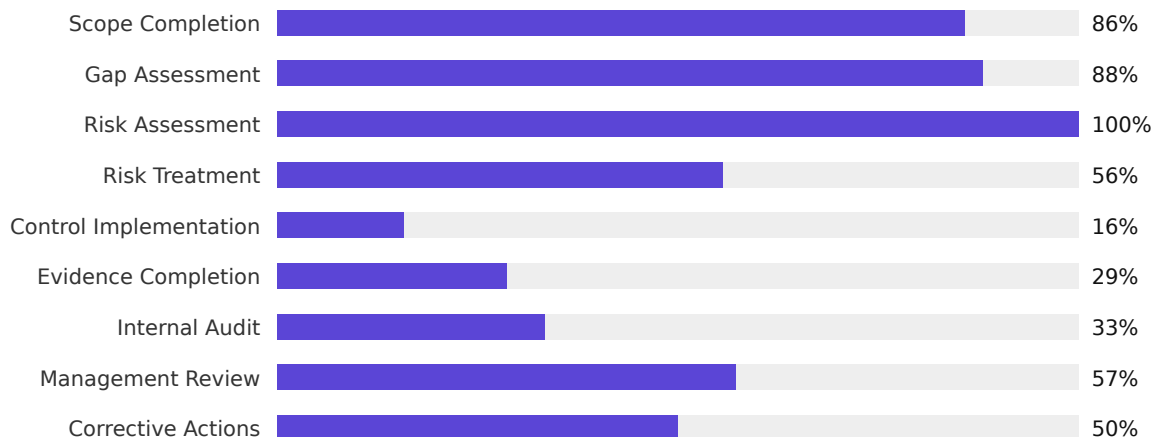


Figure · CAT.6 Readiness Indicator 各領域完成比例

Scope Completion 86%、Gap Assessment 88%、Risk Assessment 100%、Risk Treatment 56%、Control Implementation 16%、Evidence Completion 29%、Internal Audit 33%、Management Review 57%、Corrective Actions 50%。

Readiness Areas

Area	Completion	Basis
Scope Completion	86% (6 / 7)	組織全景與範圍欄位已填寫
Gap Assessment	88% (22 / 25)	條款已完成差異評估
Risk Assessment	100% (9 / 9)	風險已評估 L × I
Risk Treatment	56% (5 / 9)	風險已有處理計畫或接受決策
Control Implementation	16% (3 / 19)	適用控制已實施
Evidence Completion	29% (2 / 7)	證據已接受
Internal Audit	33% (1 / 3)	稽核計畫已完成
Management Review	57% (4 / 7)	最近一次管理審查涵蓋 9.3.2 輸入
Corrective Actions	50% (1 / 2)	矯正措施已結案

Certification Readiness Roadmap (四階段)

Stage	Item	Status	Basis
Stage 1 · Preparation & Gap Analysis	Organization Context · 組織全景	86%	CALCULATED (模組資料)
Stage 1 · Preparation & Gap Analysis	ISMS Scope · ISMS 範圍	完成	CALCULATED (模組資料)
Stage 1 · Preparation & Gap Analysis	Asset Inventory · 資產清冊	進行中	手動狀態
Stage 1 · Preparation & Gap Analysis	Gap Assessment · 差異分析	88%	CALCULATED (模組資料)
Stage 1 · Preparation & Gap Analysis	Implementation Plan · 導入計畫	進行中	手動狀態
Stage 2 · ISMS Implementation	Risk Assessment · 風險評鑑	完成	CALCULATED (模組資料)
Stage 2 · ISMS Implementation	Risk Register · 風險登錄表	完成	CALCULATED (模組資料)
Stage 2 · ISMS Implementation	Risk Treatment · 風險處理	56%	CALCULATED (模組資料)

Stage	Item	Status	Basis
Stage 2 · ISMS Implementation	Control Mapping · 控制對應	80%	CALCULATED (模組資料)
Stage 2 · ISMS Implementation	Statement of Applicability · 適用性聲明	23%	CALCULATED (模組資料)
Stage 2 · ISMS Implementation	Policies · 政策與程序	進行中	手動狀態
Stage 2 · ISMS Implementation	Evidence · 證據	29%	CALCULATED (模組資料)
Stage 2 · ISMS Implementation	Training · 教育訓練	未開始	手動狀態
Stage 3 · Internal Audit & Management Review	Internal Audit · 內部稽核	33%	CALCULATED (模組資料)
Stage 3 · Internal Audit & Management Review	Findings · 稽核發現	完成	CALCULATED (模組資料)
Stage 3 · Internal Audit & Management Review	Corrective Actions · 矯正措施	50%	CALCULATED (模組資料)
Stage 3 · Internal Audit & Management Review	Risk Status · 風險追蹤	56%	CALCULATED (模組資料)
Stage 3 · Internal Audit & Management Review	Management Review · 管理審查	57%	CALCULATED (模組資料)
Stage 3 · Internal Audit & Management Review	Continual Improvement · 持續改善	未開始	手動狀態
Stage 4 · Certification Audit Preparation	Evidence Checklist · 證據清單	29%	CALCULATED (模組資料)
Stage 4 · Certification Audit Preparation	Audit Preparation · 稽核準備 (Stage 1 / Stage 2 文件)	未開始	手動狀態
Stage 4 · Certification Audit Preparation	Finding Tracking · 缺失追蹤	50%	CALCULATED (模組資料)
Stage 4 · Certification Audit Preparation	Certification Readiness · 驗證準備度檢視	57%	CALCULATED (模組資料)

Internal Audits

ID	Area	Clause	Planned	Auditor	Status	Provenance 來源
IA-001	第 6 章 風險評鑑與處理	6.1.2	2026-10-15	示範內稽員 A	Planned	CAT6_DEFAULT
IA-002	Annex A 技術控制抽樣	A.8	2026-08-20	示範內稽員 B	Completed	CAT6_DEFAULT
IA-003	E2E 測試資料	—	2026-12-31	E2E 測試資料	Planned	USER_INPUT

Findings

ID	Audit	Clause	Type	Description	Status	Due	Provenance 來源
FD-001	IA-002	A.8.13	MINOR_NC	備份未執行還原測試紀錄 (示範)	Open	2026-10-31	CAT6_DEFAULT
FD-002	IA-002	A.8.8	OFI	弱點修補週期可縮短 (示範)	Open	2026-12-31	CAT6_DEFAULT
FD-003	IA-002	A.5.15	MINOR_NC	離職帳號未於 3 日內停用 (示範)	Closed	2026-09-10	CAT6_DEFAULT

Corrective Actions

ID	Finding	Root Cause	Action	Owner	Due	Status	Provenance 來源
CA-001	FD-001	備份程序未要求還原測試	修訂備份程序並每季執行還原演練	系統管理組	2026-10-31	In progress	CAT6_DEFAULT
CA-002	FD-003	人事異動未通知資訊部	建立人事系統自動通知	人資部	2026-09-10	Closed	CAT6_DEFAULT

Management Reviews

ID	Date	Chair	9.3.2 Inputs	Decisions	Status	Provenance 來源
MR-001	2026-07-30	示範：總經理	a, b, d, f	示範：核准 Firewall HA 預算	Held	CAT6_DEFAULT

Evidence (7 筆)

ID	Requirement / Control	Evidence	Owner	Date	Status	Risk	Provenance 來源
EV-001	5.2	資訊安全政策 v1.0	資安長	2026-05-01	Accepted	—	CAT6_DEFAULT
EV-002	A.8.13	備份排程設定截圖	系統管理組	2026-08-01	Submitted	RS-D1	CAT6_DEFAULT
EV-003	6.1.2	風險評鑑報告草稿	資訊部主管	2026-09-20	Draft	RS-B	CAT6_DEFAULT
EV-004	A.7.11	UPS 維護紀錄	總務部	2026-08-31	Accepted	RS-D2	CAT6_DEFAULT
EV-005	CIS-06	MFA 啟用清單	資訊部主管	—	Draft	RS-D3	CAT6_DEFAULT
EV-006	9.2	內部稽核計畫	內稽	2026-06-01	Rejected	—	CAT6_DEFAULT
EV-007	4.1	E2E 測試資料	E2E 測試資料	2026-09-27	Draft	—	USER_INPUT

15 Recommendations 建議

以下建議由資料規則產生（非外部基準或官方要求）：

- 為尚無處理計畫的 High / Critical 風險建立處理計畫：RS-IMP1、RS-XL1。
- 追蹤逾期處理計畫並重新排定期限：TR-002（2026-09-15）。
- 記錄殘餘風險（Residual L / I）：RS-B、RS-D4、RS-IMP1、RS-IMP3、RS-XL1。
- CIS Controls IG1 缺口 14 項，優先處理：CIS-02、CIS-03、CIS-04、CIS-06、CIS-07、CIS-08 等。
- CSF 差距 ≥ 2 的 Category：GV.RM、GV.OV、GV.SC、ID.RA、PR.AT、PR.IR、DE.CM、RS.MA、RC.RP、RC.CO，請確認改善行動與負責人。
- CIS RAM 目前使用 CAT.6 預設門檻 9；請由管理階層確認是否符合組織的風險接受準則。
- ISO 準備度完成比例低於 50% 的領域：Control Implementation、Evidence Completion、Internal Audit。
- SoA 尚有 72 項 Annex A 控制未決定適用性。
- 完成不符合事項之矯正措施：FD-001。
- 以組織實際資料取代 CAT.6 預設值（CAT6_DEFAULT），再重新產生報告。

16 References 參考文獻

- ISO/IEC 27001:2022 Information security management systems — Requirements — <https://www.iso.org/standard/27001>
- NIST Cybersecurity Framework (CSF) 2.0, NIST CSWP 29 (2024) — <https://www.nist.gov/cyberframework>
- NIST SP 800-30 Rev.1, Guide for Conducting Risk Assessments (2012) — <https://csrc.nist.gov/pubs/sp/800/30/r1/final>
- CIS Risk Assessment Method (CIS RAM) v2.2 for CIS Controls v8.1 — <https://www.cisecurity.org/insights/white-papers/cis-ram-risk-assessment-method>
- CIS Critical Security Controls v8.1 — <https://www.cisecurity.org/controls/v8-1>
- The Open Group Risk Taxonomy (O-RT) Standard / FAIR Institute — <https://www.fairinstitute.org/>
- CAT.6 Risk_Criteria.pdf（5×5 平台準則、NIST G-2 / G-3 / G-4 / G-5）

17 Disclaimer 免責聲明

本報告由 CAT.6 Cybersecurity 依使用者提供、匯入或 CAT.6 預設之資料計算產生，僅供風險管理決策參考。CAT.6 5×5 準則、CSF 0-4 尺度與 CAT.6 Readiness Indicator 為平台自定義方法，並非 ISO、NIST、CIS 或 FAIR 官方評分。

CAT.6 不是 ISO/IEC 27001 驗證機構，不提供驗證、不核發證書，亦不預測驗證結果。框架要求本文請參閱各標準正式文本。

⚠ This analysis contains CAT.6 default / assumed values. 標示 CAT6_DEFAULT 的值不代表組織實際狀況。